Assignment 1 - Security Assessment

Prepared by: Aroma Gul
Project: OWASP Juice Shop (local training application)
Assessment type: Authorized, isolated lab analysis

Scope note: OWASP Juice Shop is an intentionally vulnerable practice application, not a production project. Instructor approval is required if Parts A-C must use a real project.

Part A - CIA Impact Analysis

The following assessment describes the potential business consequences of security failures in a hypothetical organization operating a Juice Shop-style e-commerce application. Rankings are illustrative, not findings from a production assessment.

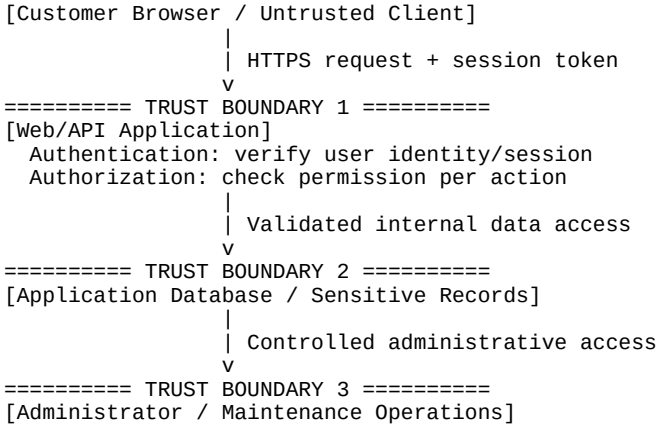
CIA pillar	Priority	Potential impact
Confidentiality	High	Exposure of customer profiles, login credentials, order information or personal data could cause privacy harm, fraud risk and loss of trust.
Integrity	Critical	Unauthorized changes to product prices, baskets, order totals or account privileges could cause financial losses and fraudulent transactions.
Availability	High	An outage could prevent customers from browsing, checking out or accessing orders, resulting in lost sales and support demand.

Highest priority: Integrity, because manipulated prices, privileges and transactions could directly undermine the correctness of orders and payments.

Recommendations: Enforce server-side authorization and validation, protect authentication sessions, monitor sensitive changes, apply least privilege, maintain tested backups and define incident response procedures.

Part B - Architecture and Trust Boundaries

Directional diagram representing a simplified, assumed architecture. It is not a verified description of Juice Shop internals.



Boundary 1: The application must not trust browser-supplied identities, prices, roles or object IDs. Authentication establishes identity; authorization separately decides what that identity can access.

Boundary 2: Application-to-database access requires restricted credentials, parameterized queries and limited privileges. Database records must not be directly accessible from the browser.

Boundary 3: Administrative operations require elevated authorization, separate access controls and audit logging.

Assumptions: The diagram assumes a browser-based client, an application/API tier and persistent data storage. Hosting, deployment topology, payment integration and production controls have not been independently verified.

Part C - Draft Rules of Engagement

Required element	Proposed rule
1. In-scope assets	Only the local OWASP Juice Shop container and its loopback endpoint, http://127.0.0.1:3000, within the Kali Docker lab.
2. Exclusions	Public websites, third-party systems, real customer data, other devices, cloud accounts and any non-lab networks.
3. Testing window	Instructor-approved lab session only; proposed window and date to be confirmed before testing.
4. Permitted / prohibited	Permitted: manual browser inspection, Burp Repeater against localhost, non-destructive checks and local Nmap discovery. Prohibited: destructive actions, denial-of-service, phishing, persistence and external scanning.
5. Escalation contact	Instructor/lab owner: [NAME / CONTACT TO CONFIRM]. Response target: [TO AGREE BEFORE TESTING].
6. Critical-finding protocol	Stop the affected activity, preserve minimal evidence, report privately to the authorized contact, and resume only after guidance.
7. Data handling	Use synthetic accounts only. Redact tokens and passwords in screenshots. Store evidence in the assignment repository with restricted access as appropriate; delete unnecessary sensitive data.
8. Authorization block	Authorized by: [INSTRUCTOR / LAB OWNER]. Scope approval: [PENDING]. Date: [PENDING]. Tester: Aroma Gul.

Approval status: Draft only. This document does not constitute authorization to assess any real-world system.